Legislation 2: Data protection (UK GDPR and the Data Protection Act 2018)

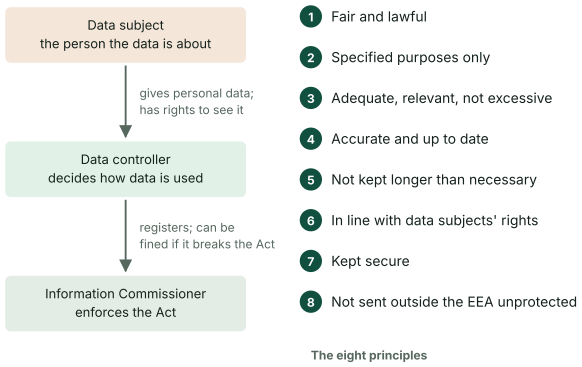
L22 FACT FILE

Specification: students should be able to

- Demonstrate knowledge and understanding of data protection law: the UK GDPR and the Data Protection Act 2018 (which replaced the Data Protection Act 1998 named in the specification)
- Demonstrate and apply knowledge and understanding of the data protection principles, including how they relate to the eight principles of the 1998 Act
- Describe the rights of the data subject
- Describe the responsibilities of the data controller, the Data Protection Officer and the Information Commission (formerly the ICO) in making sure the law is followed
- Describe measures organisations use to comply with data protection law

CCEA fact file: Moral and Ethical

Key words: UK GDPR, Data Protection Act 2018, personal data, special category data, data subject, data controller, data processor, Data Protection Officer, Information Commission, ICO, data protection principles, consent, subject access request, right to erasure, data breach



Data Protection Act roles and its eight principles

Protecting personal data

Personal data is any information about a living person who can be identified from it, such as a name, address, photo, email address or exam results. Organisations hold large amounts of it, and if it is lost or misused people can suffer fraud, identity theft or distress. Data protection law controls how organisations collect, store, use and share this data, and it gives people rights over their own information. The CCEA specification and many textbooks name the Data Protection Act 1998, but that Act was replaced in 2018. The law that applies in Northern Ireland today is the UK GDPR together with the Data Protection Act 2018, updated by the Data (Use and Access) Act 2025. It is enforced by the Information Commission (formerly the ICO). The main ideas have not changed: data must be collected fairly, used only for its stated purpose, kept accurate and secure, and deleted when it is no longer needed. Organisations that break the law can be fined up to £17.5 million or 4% of their worldwide turnover.

The principles in practice

The UK GDPR has seven principles. Personal data must be processed lawfully, fairly and in a transparent way, which means people are told what is happening to it. It must be collected for a clear purpose and not reused for something different. Only data that is adequate, relevant and necessary should be collected, so a club should not ask for details it does not need. Data must be accurate and kept up to date, and it must not be kept for longer than necessary. It must be kept secure using measures such as passwords, encryption, access rights and backups. Finally, the controller must be accountable, meaning it can show that it follows the rules. The old 1998 Act had eight principles that say almost the same things, plus a rule against sending data abroad without protection. In a scenario question, name the principle and then point to the exact detail in the scenario that breaks it.

Rights and responsibilities

The data subject is the person the data is about. They have the right to be told how their data is used, and the right to see it by making a subject access request, which is normally answered free of charge within one month. They can have wrong data corrected, ask for data to be deleted in some cases, object to direct marketing and claim compensation if they are harmed. The data controller is the organisation that decides how and why data is processed. It must follow the principles, pay a fee to the regulator, keep data secure, respond to requests and report serious breaches within 72 hours. Public bodies, including schools, must have a Data Protection Officer who advises staff and checks the rules are followed. The regulator enforces the law. On 30 September 2026, under the Data (Use and Access) Act 2025, the Information Commission (formerly the ICO) was replaced by the Information Commission, which does the same job: giving advice, investigating complaints and issuing fines.

Keeping data secure and accurate

Following the law is not just about paperwork. Organisations need practical measures. To keep data secure they use usernames and strong passwords, two-factor authentication, firewalls, anti-malware software and encryption, especially on laptops and memory sticks that might be lost. Access rights mean each member of staff can only see the data they need: a school receptionist might see a parent's phone number but not a pupil's medical notes. Regular backups protect against loss. To keep data accurate, organisations ask people to check their details, for example by sending a data collection sheet home at the start of each school year. Staff training is important, because many breaches are caused by simple mistakes such as sending an email to the wrong person or leaving a screen unlocked. Organisations should also have clear policies on how long data is kept and how it is securely deleted or shredded.

T Key terms from the mark schemes

UK GDPR
The UK version of the General Data Protection Regulation, which, with the Data Protection Act 2018, sets the rules for processing personal data in the UK.
`Credited: General Data Protection Regulation`

Data Protection Act 2018
UK law that works alongside the UK GDPR to control how personal data is collected, stored and used; it replaced the Data Protection Act 1998.
`Credited: Data Protection Act`

Personal data
Any information about a living person who can be identified from it, such as their name, address, photo or email address.

Special category data
Personal data that needs extra protection because its misuse could cause discrimination or harm, e.g. health, religion or ethnic origin.
`Credited: sensitive personal data`

Data subject
The living individual whom the personal data is about.

Data controller
The person or organisation that decides why and how personal data is processed and is responsible for following data protection law.

Data Protection Officer
A person who advises an organisation on data protection law, monitors that it is followed and acts as the contact for the regulator; required for public bodies such as schools.
`Credited: DPO`

Information Commission
The independent UK regulator that enforces data protection law, investigates complaints and can issue fines; it replaced the Information Commissioner on 30 September 2026.
`Credited: Information Commissioner / ICO`

Subject access request
A request by a data subject to see a copy of the personal data an organisation holds about them; normally answered free within one month.
`Credited: SAR`

Data breach
A security incident in which personal data is lost, destroyed, changed or disclosed without authorisation.

Exam focus

Data protection appears in almost every Unit 1 paper. You may be asked to state principles (2021 Q10(d), 2022 Q9(c), 2023 Q10(b)), describe the data controller and Data Protection Officer (2023 Q10(c)), describe the regulator's role (2022 Q9(c)), or recall data subjects' rights (2019 Q1(e)). Scenario questions such as 2024 Q11 and 2025 Q9(b) ask you to pick the right law. Older papers and mark schemes use the 1998 Act's wording and the title 'Information Commissioner' or ICO, which examiners still accept; either the 1998 principles or the current UK GDPR principles are acceptable if stated clearly. When asked to 'state' a principle, give it in full, for example 'kept no longer than necessary', not just 'time'. When applying a principle, link it to the scenario. A common mistake is confusing the data subject with the data controller, or describing the Computer Misuse Act when the question is about personal data.

Unit 1 2025 Q9	[4]	Consumer law title; data, computer misuse and copyright scenarios
Unit 1 2024 Q11	[6]	Legislation matching, online harms, protection methods
Unit 1 2023 Q10	[5]	Copyright, DPA principles, DPO and data controller
Unit 1 2022 Q9	[8]	RSI, monitor ergonomics, copyright, ICO, DPA principles
Unit 1 2021 Q10(b)–(e)	[10]	Cybercrime, access rights, DPA principles, encryption, legislation

? Check yourself

1. What is meant by the term 'data subject'? [1]
2. State four principles of data protection law. [4]
3. A shop in Ballymena stores customers' card details on an unencrypted laptop, which is stolen. State which data protection principle has been broken and describe one measure that would have prevented the breach. [3]

Answers: 1. The living individual whom the personal data is about (1). 2. Any four (1 each), current or 1998 wording: processed lawfully, fairly and transparently / collected for a specified purpose and not used for other purposes / adequate, relevant and not excessive (limited to what is necessary) / accurate and kept up to date / not kept longer than necessary / kept secure (integrity and confidentiality) / processed in line with the rights of the data subject (1998) / not transferred outside the UK/EEA without adequate protection (1998) / accountability. 3. Data must be kept secure / integrity and confidentiality principle (1); any one measure described (2): encrypt the laptop's storage (1) so data cannot be read if it is stolen (1) / do not store card details on portable devices (1), keep them on a secure server or use a payment provider (1) / password-protect the laptop with strong passwords (1) so a thief cannot log in (1).